

MITRE ATT&CK Framework



MITRE ATT&CK Framework

- Intro to MITRE
- Indicators of compromise
- Indicators of compromise – Ransomware Specific
- Introduction to MITRE ATT&CK Framework
- The ATT&CK Matrix

Labs

- Students to use the MITRE ATT&CK framework and create the defense strategy against a specific attacker group.

Intro to MITRE (MITRE ATT&CK Framework)

- MITRE is a not-for-profit organization that operates *federally funded research and development centers* (FFRDCs) and develops frameworks that help organizations improve cybersecurity, defense, and resilience.
- In cybersecurity, MITRE is best known for the MITRE ATT&CK® framework, which provides a globally adopted knowledge base of adversary behavior based on real-world cyber attacks.
- Attack scenarios mapped by MITRE ATT&CK can be:
 - Replicated by Red Teams
 - Tested by Blue Teams.

URL: <https://attack.mitre.org/>

Intro to MITRE ATT&CK

- MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a globally recognized knowledge base that documents how real-world cyber attackers operate across the entire attack lifecycle.
- It is not a security tool, but a framework used by defenders to understand, detect, and respond to adversary behavior.
- Purpose of MITRE ATT&CK
 - Understand attacker behavior, not just malware
 - Map security controls to real attack techniques
 - Improve detection, threat hunting, and incident response
 - Standardize communication between SOC, Red Team, and Blue Team



Core Structure of MITRE ATT&CK

1. Tactics (Why)

- High-level attacker objectives — what the attacker is trying to achieve.
- Examples:
 - Initial Access
 - Persistence
 - Privilege Escalation
 - Lateral Movement
 - Exfiltration

2. Techniques (How)

- Specific methods attackers use to achieve a tactic.
 - Examples:
 - Phishing
 - Credential Dumping
 - PowerShell abuse
 - Valid Accounts

3. Sub-Techniques (How in Detail)

- More granular variations of techniques.
- Example:
 - Phishing → Spear Phishing Attachment
 - Credential Dumping → LSASS Memory

ATT&CK Domains/Matrices

Domain	Focus Area
Enterprise	Windows, Linux, macOS, cloud, SaaS
Mobile	Android and iOS threats
ICS	Industrial Control Systems

ATT&CK for Enterprise tactics categories:

- Reconnaissance
- Resource Development
- Initial Access
- Execution
- Persistence
- Privilege escalation
- Defense evasion
- Credential access
- Discovery
- Lateral movement
- Collection
- Command and Control
- Exfiltration
- Impact

*MITRE ATT&CK currently identifies **188 attack techniques and 379 sub-techniques** for enterprises.*

ATT&CK for Mobile categories:

- Initial Access
- Execution
- Persistence
- Privilege escalation
- Defense evasion
- Credential access
- Discovery
- Lateral movement
- Collection
- Command and Control
- Exfiltration
- Impact

*Same categories as Enterprise except **Reconnaissance** & **Resource Development***

ATT&CK for ICS categories:

- Initial Access
- Execution
- Persistence
- Privilege escalation
- Evasion
- Discovery
- Lateral Movement
- Collection
- Command and Control
- Inhibit Response Function
- Impair Process Control
- Impact



How Organizations Use MITRE ATT&CK

- SOC alert mapping
- Threat hunting
- Red team / blue team exercises
- Security control evaluation
- Incident response planning
- Compliance and reporting

Indicators of compromise (IOCs)

- IOCs are observable artifacts or evidence that indicate a system may have been compromised by a cyberattack.
- They are used by Security Operations Center (SOC) teams to detect, investigate, and respond to security incidents.
 - Examples include malicious IPs, file hashes, suspicious processes, or abnormal logins.
- MITRE ATT&CK focuses on **attacker behavior** (Tactics & Techniques), while IOCs are **evidence left behind** when those techniques are executed.
- IOCs help defenders map detections to specific ATT&CK techniques.



Types of IOCs Mapped to MITRE ATT&CK

1. Network-Based IOCs

- Associated mainly with Command & Control, Exfiltration, and Initial Access.
- Examples:
 - Malicious IP/Domain
 - Suspicious DNS queries
 - Abnormal outbound traffic
 - Known bad URLs

Types of IOCs Mapped to MITRE ATT&CK

2. Host-Based IOCs

- Linked to Execution, Persistence, Privilege Escalation, Defense Evasion
- Examples:
 - Unknown running processes
 - Registry autorun entries
 - Local Security Authority Subsystem Service (**LSASS.exe**) access attempts
 - Disabled security services



Types of IOCs Mapped to MITRE ATT&CK

3. File-Based IOCs

- Common in Malware-based attacks
- Examples:
 - Malicious file hash
 - Dropped payloads
 - Obfuscated scripts

Types of IOCs Mapped to MITRE ATT&CK

4. Identity & Authentication IOCs

- Critical for Credential Attacks and Insider Threats
- Examples:
 - Impossible travel logins
 - Multiple failed logins
 - MFA push abuse
 - Privilege escalation events



Introduction to MITRE ATT&CK Framework

- The MITRE ATT&CK Framework (Adversarial Tactics, Techniques, and Common Knowledge) is a globally adopted knowledge base that documents real-world cyber adversary behaviors observed during attacks.
- It provides a common language for defenders to understand, detect, analyze, and respond to cyber threats based on how attackers actually operate, not just on malware names or tools.

- **Why MITRE ATT&CK Was Created:**

- Traditional security focused on:
- Signatures
- Known malware
- Perimeter defenses

MITRE ATT&CK was created to:

- Shift focus to attacker behavior
- Improve threat detection and hunting
- Help organizations understand attack progression
- Enable threat-informed defense



Benefits of Using MITRE ATT&CK

- Improves detection coverage
- Identifies security gaps
- Enhances SOC efficiency
- Enables standardized reporting
- Supports Zero Trust strategies





That's all Folks!